Care Access Navigator

Compliance 1 — Task 2: Compliance Program Development

Program governance model, stakeholders and communication strategy, Access Control Policy with approval workflow and version control, Quarterly Access Review procedure, and compliance training plan

Prepared by:	Akhila Chennamaneni, GRC Analyst (author)
Organization:	HealthLine Regional Medical Center — Care Access Navigator (CAN)
Frameworks:	HIPAA and PCI DSS v4.0.1 (see Task 1)
Date:	October 13, 2026

Purpose

Task 1 established which obligations apply. This task builds the program that meets them day to day: who governs it, how it communicates, the written policy that sets the rules for access to ePHI and the cardholder data environment, the step-by-step procedure that proves the policy is followed, and the training that makes the workforce able to follow it.

1. Program Structure and Governance Model

Governance uses a three-tier model: the Board sets direction and receives assurance, a management committee makes decisions, and working groups execute. Internal Audit reports independently to the Board's audit and compliance committee so it can challenge management.

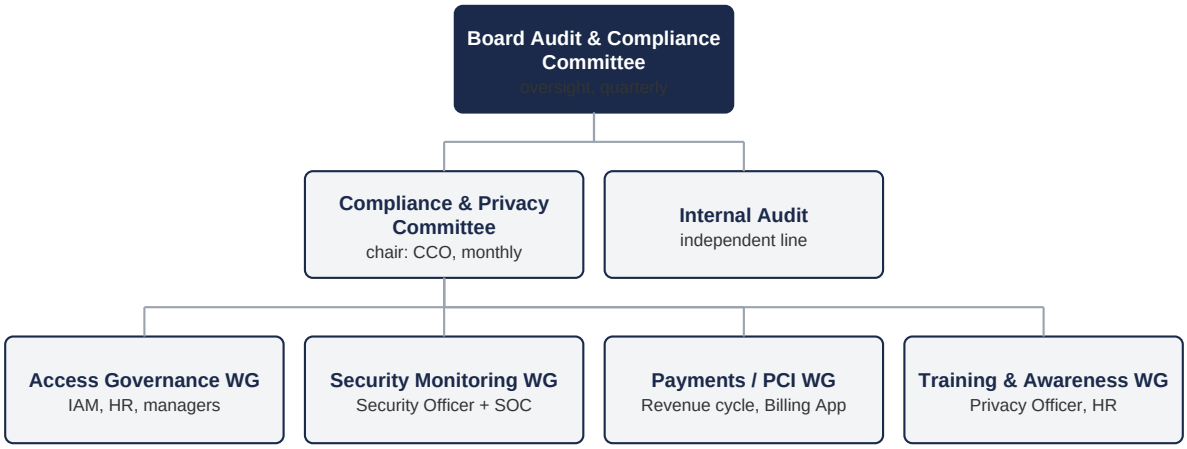

Figure 1. Compliance governance model (three tiers).

Body	Members	Decision rights	Cadence / quorum	Reports to
Board Audit & Compliance Committee	3 trustees, CCO and Internal Audit attend	Approve charter, annual plan, risk appetite; receive breach reports	Quarterly; 2 of 3 trustees	Full Board

Body	Members	Decision rights	Cadence / quorum	Reports to
Compliance & Privacy Committee	CCO (chair), Privacy Officer, Security Officer, COO, Revenue Cycle, HR, Clinical Ops	Approve policies, exceptions > 90 days, remediation priorities	Monthly; chair + 4	Board committee
Working groups (4)	Control owners and SMEs	Operate controls, draft procedures, track actions	Bi-weekly	Compliance & Privacy Committee
Internal Audit	Head of Internal Audit	Independent audit plan and opinions	Per audit plan	Board committee (directly)

Operational procedures of the program

Procedure	Summary	Owner
Policy management	Draft → review → approve → publish → attest; annual review (Section 4)	GRC Analyst
Exception management	Written request, risk assessment, compensating control, expiry (max 12 months); logged in exception register	CCO
Issue and remediation tracking	Findings logged with owner, due date and status; reviewed monthly	GRC Analyst
Reporting and hotline	Anonymous compliance hotline; non-retaliation; triage within 2 business days	CCO
Monitoring and auditing	Continuous control monitoring (Azure Policy, alerts) plus annual internal audit	Security Officer / Internal Audit
Enforcement and sanctions	Consistent sanctions for violations (HIPAA §164.308(a)(1)(ii)(C))	HR + Privacy Officer

2. Stakeholder Identification

Stakeholder	Type	Interest in compliance	Influence	Engagement approach
Patients	External	Privacy of their records; card security	Medium	Notice of Privacy Practices; portal messages
Clinicians and nurses	Internal	Fast, reliable access to ePHI	High	Clinical champions; short workflow-friendly guidance
Billing / revenue cycle	Internal	Payments must work; PCI scope	Medium	Payments/PCI working group
IT Support and IAM	Internal	Operating the controls	High	Runbooks; working group membership
Executives and Board	Internal	Penalty, reputational and financial risk	High	Quarterly dashboard and status report
HHS Office for Civil Rights	Regulator	HIPAA enforcement	High	Breach reports; audit responses
Acquiring bank / card brands	External	PCI DSS validation	High	Annual SAQ, ASV scan reports
Vendors / business associates	External	Contract terms, access	Medium	BAAs; vendor onboarding and access rules
NY Attorney General	Regulator	State breach law	Medium	Breach notifications when required

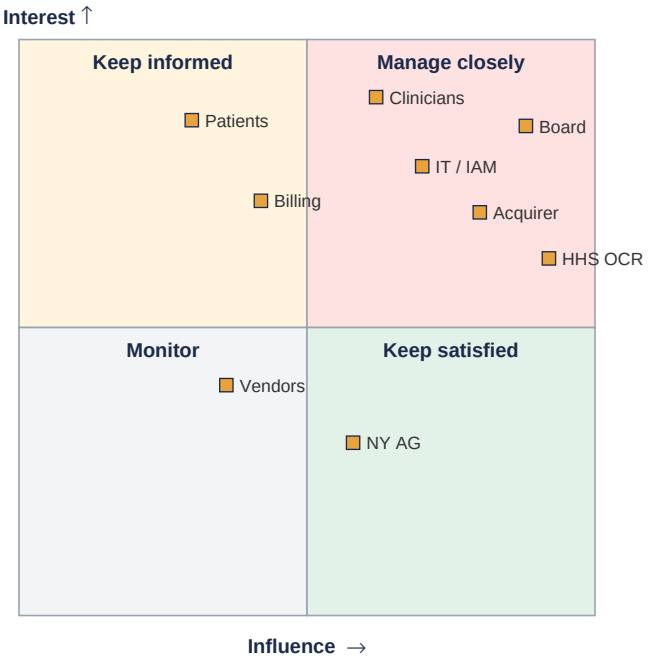

Figure 2. Stakeholder interest/influence grid.

3. Communication Strategy

Principles: plain language, role-specific messages, one source of truth (the policy portal), and two-way channels so concerns reach the committee. Every message names an owner and a feedback path.

Audience	Key message	Channel	Frequency	Owner
Board committee	Program status, top risks, decisions needed	Status report + dashboard (Task 4)	Quarterly	CCO
Executives	KPI trends, remediation progress	Committee pack, email summary	Monthly	CCO
All workforce	Policy changes, reminders, how to report	Intranet, LMS, all-staff email	On change; monthly tip	Privacy Officer
Managers	Access review tasks and deadlines	Ticket + email + calendar hold	Quarterly	IAM Analyst
Billing staff	PCI do's and don'ts	Team huddle, job aid	Quarterly	Revenue Cycle Mgr
Vendors	Access rules, BAA duties	Onboarding pack, contract	At onboarding; annually	Vendor Mgr
Regulators / acquirer	Required reports and notices	Formal letter / portal	As required	Privacy / Security Officer

4. Compliance Policy: Access Control and Identity Management

Document ID	Title	Version	Owner	Approver	Effective	Next review
CAN-POL-AC-001	Access Control and Identity Management Policy	1.0	Security Officer	Compliance & Privacy Committee	2026-12-01	2027-12-01

Approval workflow

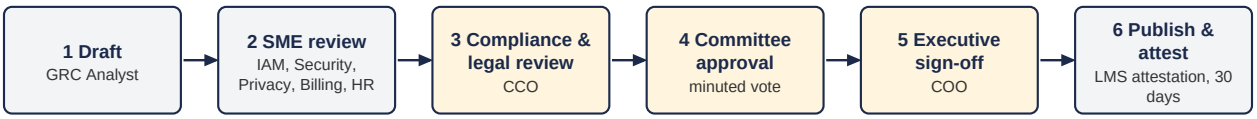

Figure 3. Policy approval workflow; steps 3–5 are formal approval gates recorded in the version history.

Version	Date	Author	Change summary	Approved by
0.1	2026-10-20	GRC Analyst	Initial draft from Task 1 requirements analysis	—
0.2	2026-11-03	GRC Analyst	SME comments: vendor access window, break-glass procedure	—
0.9	2026-11-17	CCO	Legal review: sanctions wording, regulatory references	—

Version	Date	Author	Change summary	Approved by
1.0	2026-11-24	Committee	Approved for publication; effective 2026-12-01	Committee; COO

Version control procedure

- **Numbering:** drafts 0.x; approved releases 1.0, 2.0 (material change) or 1.1 (editorial/minor change).
- **Repository:** the policy portal (SharePoint library with versioning) is the only authoritative copy; PDFs carry the version and 'uncontrolled when printed'.
- **Change log:** every version records date, author, summary and approver (table above).
- **Review triggers:** annual review, or earlier after a regulatory change, audit finding, incident or system change (e.g., new identity provider).
- **Retention:** superseded versions archived read-only for 6 years from last effective date (HIPAA §164.316(b)(2)(i)).

1. Purpose

Protect the confidentiality, integrity and availability of ePHI and account data by ensuring that only authorized, authenticated people and services access HealthLine systems, and only to the minimum extent necessary.

2. Scope

All workforce members, contractors and vendors; all systems in Care Access Navigator (EHR Simulator, Patient Portal, Billing App, HR App, Keycloak, Microsoft Entra ID and Azure resources), including the cardholder data environment.

3. Definitions

Privileged account: an account that can change security settings or other users' access. **Break-glass account**: emergency privileged account sealed for urgent patient-care or outage use. **Access review**: periodic certification by a manager that each user's access is still needed.

4. Policy statements

#	Statement	Reference
4.1	Access is granted by role, on a least-privilege and minimum-necessary basis, using the approved role catalogue (Clinician, Nurse, Billing, HR, IT Support, Security Analyst, Vendor).	§164.308(a)(4); §164.502(b); PCI 7.2.1–7.2.2
4.2	Every user has a unique ID; shared or generic accounts are prohibited except documented break-glass.	§164.312(a)(2)(i); PCI 8.2.1–8.2.2
4.3	New access requires manager approval; access is removed by end of day on termination and within 5 business days of a role change.	§164.308(a)(3)(ii)(C); PCI 8.2.5
4.4	Accounts inactive for 90 days are disabled.	PCI 8.2.6
4.5	Passwords are at least 12 characters with complexity and history of 4; accounts lock after 10 failed attempts for at least 30 minutes.	PCI 8.3.4, 8.3.6, 8.3.7
4.6	MFA is required for all remote access, all privileged access, and all access to the cardholder data environment.	§164.312(d); PCI 8.4.1–8.4.3

#	Statement	Reference
4.7	Vendor access is time-bound, enabled only when needed, MFA-protected and monitored.	PCI 8.2.7; §164.308(b)
4.8	Access is re-certified quarterly for privileged roles and at least every six months for all others (procedure CAN-PRC-AC-002).	§164.308(a)(4)(ii)(C); PCI 7.2.4
4.9	Emergency (break-glass) access is used only when patient care or a critical outage requires it, is logged and alerted, and is reviewed by the Security Officer within 1 business day.	§164.312(a)(2)(ii)
4.10	All access to ePHI and the CDE is logged and protected from alteration (policy CAN-POL-LOG-001).	§164.312(b); PCI 10.2

5. Roles and responsibilities

Security Officer owns this policy; IAM Analyst operates identity systems; managers approve and re-certify access; HR triggers joiner/mover/leaver events; users protect credentials and report suspected misuse.

6. Compliance and enforcement

Compliance is monitored by access reviews, Azure Policy, Keycloak event logs and internal audit. Violations lead to sanctions proportionate to severity, up to termination of employment or contract (HIPAA §164.308(a)(1)(ii)(C), §164.530(e)).

7. Exceptions

Requests are made to the CCO with a business justification, risk assessment and compensating control; approved exceptions expire after at most 12 months and are logged.

8. Related documents

CAN-PRC-AC-002 Quarterly User Access Review; CAN-POL-LOG-001 Logging and Monitoring; CAN-PLB-IR-001 Incident Response Playbook; Task 1 Compliance Requirements Analysis.

5. Procedure: Quarterly User Access Review

Document ID	Title	Version	Owner	Approver	Effective	Next review
CAN-PRC-AC-002	Quarterly User Access Review	1.0	IAM Analyst	Security Officer	2027-01-01	2028-01-01

Objective. Confirm every account and role in Care Access Navigator is still required and authorized, and remove anything that is not — implementing policy statement 4.8 and control AC-01.

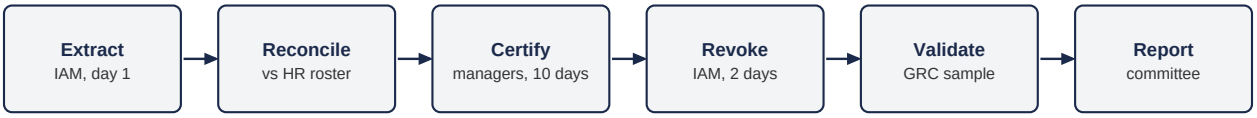

Figure 4. Quarterly access review process.

Implementation steps

#	Action	Owner	Time limit	Record produced
1	Export all Keycloak users with realm and client roles, and Entra ID app role assignments, to the review workbook (kcadm.sh / Graph export).	IAM Analyst	Day 1	Signed extract with SHA-256 hash
2	Reconcile the extract with the HR active-workforce roster and vendor contract list; flag leavers, orphans and unknown accounts.	IAM Analyst	Day 2	Reconciliation sheet
3	Send each manager the list of their staff and roles via ticket; manager marks Keep / Change / Remove.	IAM Analyst	Day 3	Review tickets
4	Managers certify; non-responses escalate to the department head on day 8 and the CCO on day 11.	Managers	Days 3–12	Certification decisions
5	Remove or change access as decided; immediately disable flagged leavers and orphans.	IAM Analyst	2 business days	Change tickets; Keycloak admin events
6	Validate (see below) and close the review; report results to the committee.	GRC Analyst	Day 15	Review report

Testing protocols (does the procedure work as designed?)

Test	How	Pass criterion
Completeness	Compare user count in the extract with a direct count in Keycloak and Entra ID	Counts match exactly
Accuracy	Re-perform role lookup for 10 random users directly in Keycloak	10/10 match the extract
Timeliness	Compare certification and removal timestamps with the time limits	100% within limits or escalated

Test	How	Pass criterion
Effectiveness	For every 'Remove', confirm the account/role no longer exists (Keycloak admin event log)	100% removed

Validation procedures (independent check by GRC)

1. Select a sample of 25 certifications (or all if fewer) and confirm each has a named manager decision and date.
2. Verify every revoked access in the sample against the live system; record pass/fail.
3. Confirm leavers on the HR roster for the quarter have no active accounts (100% check).
4. Record exceptions, open remediation items in the tracker, and file the evidence pack (extract, hash, tickets, results) in the evidence repository for 6 years.

Ready to run: The capstone already has the data this procedure needs: the Task 3 audit extract (evidence E-AC-01) lists all ten Keycloak users and their single assigned role, and E-AC-02 lists Entra ID app-role assignments.

6. Compliance Training Plan

Goal: every person who touches ePHI or payment data understands their obligations and can apply them in their own workflow. HIPAA requires training for all workforce members (§164.530(b)) and security awareness (§164.308(a)(5)); PCI DSS requires awareness training at hire and at least annually (12.6.1–12.6.3).

Module	Audience	Content outline	Time	Delivery
M1 HIPAA essentials	All workforce	PHI/ePHI, uses and disclosures, minimum necessary, patient rights, reporting	30 min	LMS e-learning
M2 Access to ePHI in CAN	All CAN users	Roles and least privilege, sharing accounts, break-glass, how audit logs work	20 min	LMS + job aid
M3 Security awareness	All workforce	Phishing, passwords and MFA, device security, incident reporting	25 min	LMS + phishing sims
M4 PCI DSS for billing	Billing staff	Card data handling, hosted payment fields, never write down PAN/CVV, scripts on payment page	20 min	Live huddle + quiz
M5 Privileged access	IT Support, IAM, Security	Admin duties, logging, change control, access reviews	45 min	Live workshop
M6 Manager duties	Department managers	Approving access, quarterly reviews, sanctions process	20 min	Live / recorded
M7 Vendor obligations	Vendors	BAA duties, remote-access rules, incident reporting	15 min	Onboarding pack + attestation

Delivery methodology and schedule

- **Onboarding:** M1–M3 (plus role modules) completed before access is granted to ePHI or the CDE, and no later than 30 days after hire.
- **Annual refresher** for all modules; **monthly micro-learning** tips; **quarterly phishing simulations** with just-in-time coaching for anyone who clicks.
- **Event-driven training** after a policy change or incident (e.g., a 10-minute refresher on access reviews after an audit finding).
- Accessibility: captions, screen-reader-friendly LMS content, Spanish versions of M1–M3.

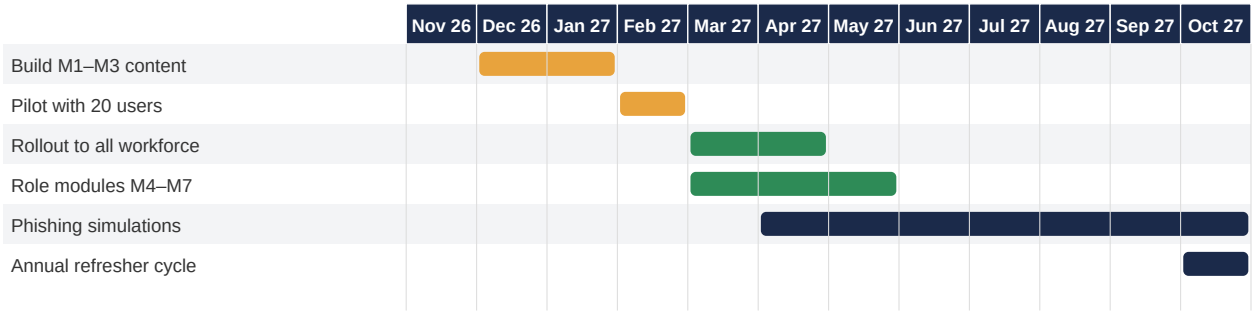

Figure 5. Training rollout timeline.

Assessment approach

Level (Kirkpatrick)	Measure	Target
1 Reaction	Post-course survey (relevance, clarity)	≥ 4.0 / 5
2 Learning	Pre/post quiz; scenario questions	≥ 80% pass mark; 2 attempts
3 Behaviour	Phishing click rate; access-review on-time rate; PHI-handling audit sample	Click rate < 5%; reviews ≥ 95% on time
4 Results	Privacy incidents caused by human error; audit findings related to training	Down 50% year on year
Records	Completion, scores and attestations kept in LMS	Retained 6 years

Evidence of training design — Module M2 storyboard

Screen	Content	Interaction
1	Why access matters: a real-style story of a billing clerk viewing a neighbour's chart	Video (60 s)
2	Your role in CAN: what Clinician, Nurse and Billing can see	Click-to-reveal by role
3	Minimum necessary in practice	Drag the data you need to the task
4	Everything you open is logged (Keycloak events, Azure Monitor alerts)	Animated log trail
5	Break-glass: when it is and is not allowed	Branching scenario
6	Knowledge check (5 questions) and attestation	Quiz ≥ 80% + e-signature

Sample knowledge-check questions (with answer key)

#	Question	Correct answer and rationale
1	A colleague asks to use your login because theirs is locked. What do you do?	Refuse and direct them to IT Support — unique IDs are required (policy 4.2).
2	You are in Billing. Can you open a patient's clinical notes to check a diagnosis code?	No — use the coded claim data; clinical notes exceed minimum necessary.
3	A patient reads their card number to you over the phone. Where do you record it?	Nowhere — enter it only in the processor's hosted payment field (PCI 3.3).
4	You receive an urgent email asking you to re-enter your password at a new link.	Report it with the 'Report phish' button; do not click.
5	When must you report a possible privacy incident?	Immediately, to the Privacy Officer or hotline — the 60-day breach clock may already be running.

Summary

The program now has a governance model with clear decision rights, an identified stakeholder map and communication matrix, an approved Access Control Policy with formal workflow and version control, an executable and testable Quarterly User Access Review procedure, and a role-based training plan with measurable assessment — each mapped to HIPAA and PCI DSS requirements.